

Chapter 14

Managing Third Party Risk

Third-Party Risk Management

Organizations rely on
external vendors

Third-party risk is common

Vendor security
impacts organization

Must be actively managed

Supply Chain Risk

Includes all upstream vendors

Provides organizational inputs

Vendor compromise creates risk

Can impact dependent systems

Supply Chain Attack Example

Hardware compromise scenario

Malicious
components introduced

Affected systems deployed

Demonstrates downstream risk

Software Composition Analysis

Analysis third-party software

Identifies external components

Detects vulnerabilities

Supports risk identification

SCA Risk Detection

Identifies vulnerable libraries

Detects licensing issues

Finds supply chain risks

Maps components to CVEs

Software Bill of Materials (SBOM)

Lists software components

Tracks dependencies

Supports transparency

Aids vulnerability management

SBOM Benefits

Identifies affected components

Tracks vulnerability exposure

Supports supply chain security

Improves software insight

Chapter 14

Remediation Difficulties

Business Operational Impact

Patching may disrupt operations

Production systems must
remain active

Security cannot
interrupt business

Updates may require off-hours

Business Continuity Constraints

Must maintain ongoing operations

Security changes can cause downtime

Workarounds required

Impacts remediation timing

Contractual and SLA Constraints

SLAs define uptime requirements

Downtime may violate agreements

Patching can interrupt services

Alternate systems may be required

Organizational Structure Limitations

Departments manage
own systems

Central teams lack control

Limited oversight across units

Response may be delayed

Technical Constraints

Degraded system performance

Patch availability issues

Legacy systems limitations

Proprietary system challenges

Patch Impact Risks

Patches may
reduce performance

System slowdowns can occur

May affect operations

Alternate actions may be needed

Lack of Available Patches

No solution available

Vender may not be aware

Zero-day vulnerabilities exist

Patch release may take time

Unsupported and Legacy Systems

Software no longer supported

Vendors may be unavailable

No updates or fixes provided

Systems remain vulnerable

Vendor Response Limitations

Vendors may delay fixes

Even known issues may not
be resolved

External control limits response

Systems may require isolation

Chapter 14

Metrics

KPIs and Trends

KPIs measure performance

High-level operational indicators

Trends show growth or decline

Support decision making

Risk Tracking Metrics

Identify top organizational risks

Used in assessments

Highlight critical issues

Support risk awareness

Service Level Agreements (SLA)

Defines service expectations

Sets performance metrics

Includes uptime requirements

Defines response expectations

High Volume Metrics

Tracks number of alerts

Includes notifications
and warnings

Covers incident reports

Measures security workload

False and True Positives

True positives indicate real issues

False positives are incorrect alerts

High false positive impact teams

Affects efficiency and morale

Mean Time to Detect

Time to identify issue

Measures detection speed

Indicates visibility capability

Impacts response readiness

Mean Time to Respond

Time from detection to action

Measures response speed

Tracks reaction time

Impacts incident handling

Mean Time to Close

Tracks ticket lifecycle

Measures issue duration

Follows work order timeline

Ends at closure

Mean Time to Remediate

Time to fix issue

Measures technical resolution

Separate from ticket closure

Focuses on remediation

Phishing Campaign Metrics

Tracks click rates

Measures user susceptibility

Identifies training needs

Evaluates awareness levels